

ResolvX

Incident Management Policy

Topic-Specific Policy - Incident Governance (Governs the Incident Response Plan)

POL-015 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-015
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	GRC Lead
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A5.24, A5.25 · NIST CSF 2.0 RS.MA, RS.CO · SOC 2 CC7.3, CC7.4

1. Purpose

This Incident Management Policy establishes incident management as an organisation-wide obligation at ResolvX, wherein who must report a suspected incident, who has authority to formally declare one, and how ResolvX learns from every incident once it closes.

The operational detail of how ResolvX detects, contains, and recovers from a security incident — severity levels, the incident response team's technical roles, containment procedures, and regulatory notification timelines — is already fully defined in the Incident Response Plan. This policy governs the accountability structure and organisational obligations that sit around that plan, including the incident categories and the people (HR, third parties) the plan's technical team doesn't already cover.

2. Scope

This policy applies to all incidents affecting ResolvX, not only technical security events:

- Security incidents (unauthorized access, malware, data exfiltration) are governed operationally by the Incident Response Plan.
- Availability incidents that do not have a security cause are governed operationally by the BCP/DR Policy (POL-008) once recovery is engaged.
- Suspected insider misconduct involving ResolvX systems or data.
- Incidents caused by, or originating at, a third-party vendor (per POL-005's TPRM programme).

Where an incident involves potential personal data breach requiring regulatory notification, the notification decision itself follows the dedicated Breach Management Policy; this policy governs how the incident is managed and reviewed as an organisational event.

3. Relationship to the Incident Response Plan

- This policy (POL-015) answers: who must report, who can declare, how insider and third-party incidents are handled, and how lessons get captured after the fact
- The Incident Response Plan answers: severity classification, technical containment steps, the incident response team's operational roles, and regulatory notification timelines

4. Universal Reporting Obligation

Every ResolvX employee, contractor, and vendor with system access is obligated to report a suspected incident immediately upon noticing it as reporting is not limited to the Incident Response Team, and delay while trying to confirm the issue independently is not appropriate. Suspected incidents are reported via the [#security-alerts](#) channel or directly to the GRC Lead, consistent with the escalation path already defined in the Incident Response Plan. Anonymous reporting is available via the GRC Lead for anyone not comfortable reporting by name, consistent with POL-002 §11.

A good-faith report made in error, or one that turns out not to be an actual incident, carries no negative consequence for the reporter. The only reporting failure that carries consequence under §9 is knowingly failing to report a suspected incident.

5. Incident Declaration Authority

A report is not the same as a declared incident. GRC Lead (as Incident Commander under the Incident Response Plan), or the on-call designee during the out-of-hours escalation path, holds authority to formally declare an incident and assign its initial severity. Once declared, an incident is tracked to closure regardless of whether its severity is later revised, which is consistent with the Incident Response Plan's rule that severity may be escalated but never de-escalated.

6. Insider & HR-Involved Incidents

The Incident Response Plan's team is built for technical response and does not include HR. Where an incident involves suspected misconduct by a ResolvX employee or contractor — rather than an external threat — HR is engaged alongside the standard incident response team from the point of declaration, not brought in afterward:

- GRC Lead notifies Head of HR at the same time as the standard Incident Response Team is activated, for any incident suspected to involve insider misconduct.
- Legal is engaged to advise on employment law and privilege considerations before any evidence is used to support disciplinary action, in addition to Legal's existing regulatory role under the Incident Response Plan.
- Evidence handling still follows the Incident Response Plan's chain-of-custody requirements, since insider-incident evidence is often the most likely to face later legal scrutiny.

7. Third-Party Caused Incidents

An incident originating at a vendor rather than at ResolvX is still managed through this policy and the Incident Response Plan for ResolvX's own response, while the vendor's own notification obligations to ResolvX are governed by the Vendor Management Policy (POL-005) and the underlying contract. GRC Lead confirms the vendor's tier and contractual notification obligations as an early step in assessing a suspected third-party caused incident.

8. Post-Incident Review

Every declared incident is followed by a review:

Severity	Review Required Within	Owner
P1 / P2	5 business days of closure	GRC Lead, with the Incident Response Team
P3 / P4	10 business days of closure	GRC Lead

The review documents what happened, what worked, what didn't, and produces specific corrective actions. Any control failure identified is logged as a Corrective Action Plan item with a named owner. So, a post-incident review that doesn't produce a tracked action item has not actually closed the loop.

9. Roles & Responsibilities

9.1 GRC Lead

- Owns this policy and holds incident declaration authority (§5).
- Runs post-incident reviews and tracks resulting Corrective Action Plan items (§8).

9.2 Head of HR

- Engaged for any incident suspected to involve insider misconduct (§6).

9.3 Legal

- Advises on employment law and evidentiary privilege for insider incidents, in addition to the regulatory role already defined in the Incident Response Plan.

9.4 All Personnel

- Report any suspected incident immediately (§4).

10. Compliance and Enforcement

Knowingly failing to report a suspected incident or bypassing the declaration authority in §5 to independently manage an incident without GRC Lead's involvement, is addressed under POL-002's disciplinary process.

11. Document Control

Policy ID	POL-015
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	GRC Lead
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A5.24, A5.25 · NIST CSF 2.0 RS.MA, RS.CO · SOC 2 TSC CC7.3, CC7.4
Related Documents	POL-002 (Acceptable Use Policy), POL-005 (Vendor Management Policy), POL-008 (BCP/DR Policy & Plan), POL-016 (Breach Management Policy), Incident Response Plan

Appendix A - Incident Report Form

Used by anyone submitting a report under §4. A short, quickly completed form matters more here than a comprehensive one as the goal is to get a suspected incident reported within minutes, not to produce a polished document. GRC Lead fills in gaps during declaration (§5), not the reporter.

Field	Entry
Reporter Name	[Name or "Anonymous" if submitted without attribution]
Date / Time Observed	[Date and time, as precisely as known]
System / Asset Affected	[What system, application, account, or device as per the asset register (POL-011) if known]
What Was Observed	[Plain description of what looked wrong, unexpected, or suspicious]
Suspected Category	[Security / Availability / Insider / Third-party caused / Unsure]
Immediate Action Taken (if any)	[e.g., disconnected device, changed password or "None"]
Reporter Contact	[Email or phone for follow-up]

Appendix B - Incident Declaration & Stakeholder Notification Template

Used by GRC Lead upon formally declaring an incident (§5), to notify the Incident Response Team and relevant internal stakeholders. This is an internal operational notice where a declared incident also involves a suspected personal data breach, the regulatory and affected-individual notification templates in POL-016's appendices govern that separate, legally significant notification.

Subject: [P1/P2/P3/P4] Incident Declared - [Short Description]

Incident ID: [ID] Declared By: [GRC Lead name] Declared At: [Date/Time] Severity: [P1 - P4]

Summary

[One to two sentences: what is affected and the current operational impact.]

Current Status

[Contained / Investigating / Recovering / Monitoring as of the time of this notice.]

Team Activated

[Roles engaged per the Incident Response Plan's team table, plus HR/Legal if activated under §6.]

Next Update

[Time the next status update will be sent, consistent with the severity's response SLA.]

Client / External Communication

[State whether client-facing communication is required for this incident, and who whether if the CISO holds client communication authority under the Incident Response Plan. If the incident may involve a personal data breach, note that POL-016's breach risk assessment (§4) is being run in parallel and no regulatory or affected-individual notification proceeds ahead of that assessment.]

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		